SENTINEL

Autonomous Enterprise Security & Intelligence Ecosystem

Detect. Understand. Predict. Prevent. Respond.

PRODUCT & ARCHITECTURE OVERVIEW

SENTINEL is a proposed enterprise security platform that correlates authorised telemetry, asset relationships and threat context to help organisations understand what happened, what may be affected next, and what defensive action is appropriate.

SENTINEL is the parent ecosystem, not one giant build. Its divisions are independently buildable products, each with its own problem statement, architecture, MVP, data plan and tests. They can integrate later through shared data contracts.

Document: Umbrella product specification

Status: Concept / architecture definition

Version: 1.0

1. Executive Summary

Organisations depend on interconnected users, devices, applications, servers, cloud services, networks and data stores. Security tools often observe only part of this environment. SENTINEL proposes a shared intelligence layer that correlates events with assets and their relationships, then explains potential technical and business impact.

2. Product Vision & Principles

- **Authorised visibility:** collect data only from explicitly enrolled systems and approved integrations.
- **Relationship-aware security:** interpret events using permissions, dependencies and asset context.
- **Explainability:** expose evidence, assumptions, confidence and reasoning.
- **Least privilege:** use scoped access and temporary elevation, not permanent admin power.
- **Human oversight:** require approval for disruptive or high-impact actions.
- **Privacy by design:** minimise collection, define retention and restrict access.
- **Modular engineering:** each division can be built and tested independently.

3. Core Intelligence Model

SENTINEL is organised around three foundations: **Events** (time-stamped observations or actions), **Assets** (users, devices, servers, applications, databases and documents), and **Relationships** (access, authentication, sharing, network reachability and dependencies).

4. SENTINEL's 18 Divisions

01. Device Intelligence

Authorised endpoint/server inventory and posture: OS, software, processes, configuration, patching, encryption, firewall and health. Collect supported identifiers and network observations: UUID, hostname, serial where permitted, IP, MAC, interfaces, subnet, gateway, DNS, VPN and historical assignment.

Standalone MVP: MVP: enrolled endpoint inventory, heartbeat, basic posture checks and device timeline.

02. Identity Intelligence

Authentication, MFA, sessions, privileges, dormant identities, suspicious sign-ins and excessive permissions. Supports controlled session revocation and just-in-time privilege workflows.

Standalone MVP: MVP: identity event ingestion, risky-login rules and session inventory.

03. Communication Intelligence

Approved enterprise email and collaboration integrations. Detect phishing, impersonation, malicious links, suspicious forwarding and risky sharing using authorised APIs and audit metadata.

Standalone MVP: MVP: one provider integration and explainable email-risk detections.

04. Web Intelligence

External security intelligence from CISA KEV, NIST NVD, MITRE ATT&CK;, CERT advisories and vendor bulletins; correlate vulnerabilities with actual assets.

Standalone MVP: MVP: ingest CVEs/KEV and match against sample software inventory.

05. Network Intelligence

Authorised network asset mapping, IP/MAC/DNS/ports/subnets/VLANs, traffic signals, suspicious DNS/outbound activity, segmentation and lateral-movement indicators.

Standalone MVP: MVP: lab network map and imported flow/log analysis.

06. Data Intelligence

Data-loss prevention and sensitive-content protection. Potential capabilities include OCR, classification, image/document fingerprinting, forensic watermarking, print controls and policy restrictions.

Standalone MVP: MVP: classify sample documents and demonstrate watermarking or controlled sharing.

07. Behaviour Intelligence

User/device baselines and deviations in login, file access, downloads, privilege, applications and network activity. An anomaly is an investigation signal, not proof of malicious intent.

Standalone MVP: MVP: simulated activity dataset with transparent rules or baseline scoring.

08. Threat Intelligence

Correlate internal events with indicators, malware information, campaigns, techniques and known adversary behaviours.

Standalone MVP: MVP: IOC enrichment for IPs, domains and file hashes from trusted feeds.

09. Blast Prediction Matrix (BPM)

Flagship graph-based analysis. Models users, devices, servers, apps, databases, documents, departments and vendors; relationships represent access, login, network reachability, sharing and dependencies. Estimates which assets may be affected after an incident and explains likely paths, confidence and potential impact.

Standalone MVP: MVP: graph-based blast-radius analysis on synthetic assets with paths, evidence, confidence and recommendations.

10. Digital Forensics

Preserve and correlate incident evidence, build timelines, record hashes, reconstruct relevant account/device/file activity and generate reports with chain-of-custody metadata.

Standalone MVP: MVP: sample-log ingestion, incident timeline and evidence report.

11. Autonomous Response Intelligence

Coordinate defensive actions such as session revocation, account restriction, document access changes, domain blocking, endpoint isolation and forensic collection. Actions are policy-governed and auditable.

Standalone MVP: MVP: advisory-only recommendations or human-approved actions in a controlled lab.

12. Guardian Layer

Protect SENTINEL's own integrity and privileged operations through privilege tiers, temporary elevation, approvals, signed components, tamper-evident audit and independent recovery paths.

Standalone MVP: MVP: threat model, signed-update verification and auditable temporary-privilege prototype.

13. Digital Twin

Continuously updated model of enrolled devices, users, apps, servers, databases, cloud services, documents and dependencies. Visualises changes and access paths; supplies context to BPM.

Standalone MVP: MVP: graph-backed environment model with change history and interactive visualisation.

14. Application Intelligence

Application/process inventory, permissions, browser extensions, file/network access, unapproved applications and suspicious application behaviour.

Standalone MVP: MVP: process/application inventory from a controlled endpoint or sample telemetry.

15. Policy & Enforcement Engine

Policy Decision Point evaluates user, device trust, application, resource sensitivity and context; Policy Enforcement Points apply approved restrictions.

Standalone MVP: MVP: policy simulator for view, download, print and share decisions.

16. Data Lifecycle Intelligence

Tracks classification, ownership, retention, access and sharing history through create, classify, store, access, share, print, archive and delete.

Standalone MVP: MVP: document registry with classification, owner, retention and access history.

17. Integration Fabric

APIs, webhooks, connectors, event normalisation, authentication, retries and integration-health monitoring across identity, cloud, collaboration, endpoint and security platforms.

Standalone MVP: MVP: one or two connectors and a normalised event contract.

18. Exposure & Attack-Path Intelligence

Authorised discovery of external exposure, internet-facing services, misconfigurations, vulnerability exposure and privilege paths; prioritises remediation using reachability and business criticality.

Standalone MVP: MVP: controlled lab topology or imported asset/vulnerability dataset.

5. Shared Intelligence Pipeline

Stage	Purpose
1. Data collection	Approved agents, APIs, logs, feeds and imports.
2. Event normalisation	Convert provider-specific data into common event schemas.
3. Asset identification	Resolve observations to known users, devices and services.
4. Identity correlation	Connect accounts, sessions and device identities.
5. Threat enrichment	Add CVE, IOC, technique and advisory context.
6. Relationship analysis	Update access, dependency and communication edges.
7. BPM evaluation	Estimate affected assets, paths, confidence and impact.
8. Policy decision	Evaluate what should be allowed, restricted or escalated.
9. Alert / response	Notify operators or request an approved defensive action.
10. Forensic preservation	Retain evidence and an auditable incident timeline.

6. Reference Technical Architecture

- **Frontend:** React + TypeScript; React Flow for graph exploration; Recharts for metrics.
- **Backend:** Python + FastAPI.
- **Data:** PostgreSQL for core records; JSON for event interchange; Redis only where useful.
- **Graph analysis:** NetworkX initially; adopt a graph database only when scale/query needs justify it.
- **Collection:** signed endpoint agent or approved SaaS APIs; Go/Rust only when a native agent is needed.
- **Observability:** structured logs, metrics, traces and tamper-evident audit records.
- **Deployment:** Docker for reproducible development; orchestration only when justified.

Avoid adopting Kafka, Neo4j and Kubernetes merely to look enterprise-grade. Start with the smallest architecture that proves the core value.

7. BPM: Flagship Analytical Engine

Core question: If this event or asset is compromised, what else could be affected, through which relationships, and with what level of confidence?

- **Nodes:** users, devices, servers, applications, databases, documents, departments and vendors.
- **Edges:** ACCESS, LOGIN, NETWORK, SHARES_WITH, DEPENDS_ON and other evidence-backed relationships.
- **Inputs:** initiating event, graph snapshot, asset criticality, data sensitivity, exposure and control strength.
- **Outputs:** affected assets, plausible paths, risk estimate, confidence, supporting evidence and recommended action.

Illustrative example: User A → laptop (0.9) → file server (0.6) → HR database (0.5). A simple path estimate is 0.9 × 0.6 × 0.5 = 0.27. If database criticality is 10, an illustrative risk contribution is 2.7.

These probabilities are heuristic until calibrated and validated. BPM must not present estimates as certainty. Confidence should reflect evidence quality, freshness and provenance.

8. Admin Command Center

- Global overview: incidents, enrolled assets, device posture, identity risks and integration health.
- Incident workspace: IDs, timestamps, users/devices/resources, severity, confidence, evidence and timeline.
- BPM view: affected graph nodes, propagation paths, impact estimate and explanation.

- Response workspace: recommendations, approvals, action history and recovery status.
- Governance: roles, policies, retention, audit logs, integrations and reporting.

9. Security, Privacy & Governance

- **Explicit enrolment:** telemetry comes only from systems the organisation is authorised to monitor.
- **Least privilege:** no permanent shared master credential; use scoped service identities and temporary elevation.
- **Strong authentication:** MFA for administrators, secure sessions and role-based access.
- **Encryption:** protect data in transit and at rest with sound key management.
- **Audit:** record administrator actions, policy decisions, approvals and evidence access.
- **Privacy:** define purpose, collection boundaries, retention and employee notice/consent as applicable.
- **Response safety:** keep high-impact actions human-approved until safeguards are proven.
- **Resilience:** signed releases, integrity checks, backups and independent recovery.

Identifier limitations: MAC addresses can be spoofed or randomised and are generally not visible end-to-end across routed networks. IP addresses can change through DHCP, NAT and VPNs. Correlate them with endpoint identity and trusted network records; do not treat one identifier as definitive.

Watermarks can support leak attribution but do not guarantee prevention. External cameras and compromised endpoints can bypass local controls. Anomaly detection signals unusual behaviour; it does not prove intent.

10. Independent Project Strategy

Each division should have its own engineering specification. A project can deliver standalone value and later become a SENTINEL integration. The umbrella document defines shared principles; each division's PROJECT.md defines implementation scope.

- **PROJECT.md:** problem, users, requirements, architecture, algorithms, MVP, exclusions, test plan, risks and success criteria.
- **DATA.md:** data sources, schemas, synthetic-data strategy, privacy boundaries and retention.
- **ARCHITECTURE.md:** components, interfaces, event contracts, deployment and trust boundaries.
- **THREAT_MODEL.md:** assets, trust boundaries, abuse cases, attack surfaces, mitigations and residual risk.

11. Suggested Repository Structure

SENTINEL/
■■■ PRODUCT.md
■■■ architecture/ARCHITECTURE.md
■■■ governance/SECURITY-AND-PRIVACY.md
■■■ projects/
  ■■■ bpm/PROJECT.md
  ■■■ digital-twin/PROJECT.md
  ■■■ trace/PROJECT.md
  ■■■ cve-intelligence/PROJECT.md
  ■■■ attack-path/PROJECT.md
  ■■■ behaviour-intelligence/PROJECT.md
  ■■■ device-intelligence/PROJECT.md
  ■■■ digital-forensics/PROJECT.md

12. Initial Build Priorities

The full ecosystem remains the long-term vision. For early demonstrations, prioritise divisions that prove a clear capability with controlled or synthetic data. BPM + Digital Twin is a strong flagship pairing; CVE-to-asset correlation and attack-path analysis are also practical standalone builds.

- **BPM + Digital Twin:** demonstrate how an incident can affect connected assets.

- **CVE Intelligence:** match vulnerability records to a known software inventory.
- **Attack-Path Intelligence:** show reachable paths and explain why they matter.
- **Device Intelligence:** build an authorised inventory and posture collector.
- **Trace / Data Intelligence:** prototype watermarking and leak attribution with test documents.

13. Definition of Done for Any Division

- A precise problem statement and clearly identified user.
- A documented threat model, privacy boundary and list of exclusions.
- A working MVP demonstrating one core capability end to end.
- Reproducible test data and test cases, including failure cases.
- Explainable outputs with provenance and confidence where applicable.
- A deployment/run guide and documented API or event contract.
- Measured success criteria and known limitations.

14. Closing Statement

SENTINEL is an ambitious umbrella vision, but it should be engineered through focused, independently testable products. Its long-term advantage is not the number of dashboards or modules; it is the quality of the relationships it understands, the accuracy of its reasoning, and the safety of the actions it recommends.

This is a concept-level product specification, not a claim that all capabilities currently exist or have been validated. Each division requires its own detailed requirements, implementation, testing and security review.